

Setnayan — Privacy Compliance Dossier

For submission to the National Privacy Commission (NPC), Republic of the Philippines

Status: DPO-prepared submission draft — pending final external legal review before filing. This dossier is prepared by the Data Protection Officer to support NPC registration and to serve as Setnayan's Records of Processing Activities (ROPA) and Privacy Impact Assessment (PIA). It is reasoned from RA 10173 (Data Privacy Act of 2012), its IRR, and NPC issuances. It is **not legal advice**; the Personal Information Controller should have it reviewed by external counsel before submission.

Prepared: 2026-07-12. **Version:** 2.0 (last updated **2026-07-13**). **Governing law:** RA 10173 + IRR + NPC Circulars.

What changed in v2.0 (2026-07-13): the ROPA (§3) and the sensitive-personal-information declaration (§5) were expanded from a customer-centric, biometric-only scope to cover **every category the platform actually processes** — self-profile religion / civil status / gender, the dependents & godparents family graph (minors' data), event honoree / specialty data (incl. christening child data and gender-reveal due-date), e-gift receiving handles, and the vendor-verification identity surface. The subprocessor list (§7) was completed (Persona, TikTok, Suno added). Retention (§3, §8a) was aligned to the **Data Retention Schedule (2026-07-11)** with its statutory floors. Driven by the reconciliation in `Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md`. Items still requiring owner/counsel action are consolidated in §11.

1. Personal Information Controller (PIC) and Data Protection Officer (DPO)

Field	Detail
Registered business name	SETNAYAN SOFTWARE DEVELOPMENT SERVICE
Legal form	Sole proprietorship (DTI-registered 2026-06-25, national scope)
PIC under RA 10173	The proprietor. A sole proprietorship has no legal personality separate from its proprietor, so the proprietor is the Personal Information Controller.
Data Protection Officer	The proprietor (Indalecio S. Casasola II), serving the DPO function directly
DPO contact	dpo@setnayan.com (the contact published on every public surface — privacy notice, cookie policy, acceptable-use, site footer, and schema.org metadata. Older internal/corpus documents that still list <code>iscasasolaii@gmail.com</code> are to be aligned to this address — see §11.)
Data subject response SLA	15 business days (the period published in the live privacy notice. The older binding Privacy & Security Policy §9 states 7 business days and is to be reconciled up to 15 — see §11.)
BIR registration	Under the proprietor's existing TIN
NPC registration	To be filed under the registered business name

Public privacy notice	Published at setnayan.com/privacy (effective 2026-05-13; last updated 2026-07-13 via app PR #3215, adding the faith / family / honoree / e-gift disclosures + Anthropic/Suno subprocessors). The opt-in biometric and device-identifier sections were already present on origin/main .
-----------------------	---

2. Description of the Data Processing System

Setnayan is a Philippines-first life-events platform (V1 surface: weddings, with additional event types — birthday, debut, christening, gender reveal, anniversary, reunion, corporate and others — progressively enabled). It provides three role-routed doorways:

- **Couples / customers** plan an event end-to-end (guest lists, vendors, budget, schedule, invitations, media galleries) and optionally record personalization and family-milestone details.
- **Vendors** run a business profile, submit verification documents, and receive inquiries.
- **Administrators** (the Setnayan team) run operations, payment reconciliation, and integrity / fraud review.

Personal data is processed to deliver the planning service, to enable couple↔vendor communication, to process in-app payments, to verify vendor legitimacy, and to protect the marketplace from fraud. Processing is web-based; data resides with the subprocessors in §7.

3. Records of Processing Activities (ROPA)

Personal-data categories, purposes, legal bases, and retention. Retention detail is maintained in the companion **Data Retention Schedule (2026-07-11)**; periods marked (*counsel*) await external ratification. **Build-state** column: *Active* = collected in production now; *Gated* = shipped behind a feature flag; *Dormant* = built but not yet collecting.

#	Data category	Data subjects	Purpose	Legal basis (RA 10173)	Retention	Build-state
1	Account / profile — email, hashed password, display name, optional phone, profile photo	Couples, vendors, admins	Account creation + authentication; deliver the service	§ 12(a) consent; § 12(b) contract	Life of account + 30-day soft-delete tail, then purge	Active
2	Self-profile personalization — religion, civil status, gender/sex (<i>sensitive PI</i>) + per-field consent timestamps (religion_consent_at, civil_status_consent_at, sex_consent_at)	Account holders (adults)	Optional personalization — faith-appropriate suggestions, event-type relevance, salutation. Reference-only; not required to use the service	§ 13(a) explicit consent (self-provided, timestamped; withdrawable)	Life of account; cleared on withdrawal or account deletion	Active (self opt-in; no feature flag)

3	Event data — guest lists, vendor records, budget items, schedule, mood-board palettes	Couples (and guests they enter)	Deliver event-planning features the user is paying for	§ 12(b) contract	5 years from event date (<i>counsel</i>)	Active	
4	Event honoree / specialty details — e.g. christening child name, birth date, gender + rite; gender-reveal parents' names + expected due-date ; birthday celebrant name + age; debut celebrant; wedding ceremony rite (<i>contains sensitive PI + minors' data — see §5</i>)	Couples; the named honoree (may be a minor or a non-account third party)	Configure the specific event the couple is planning	§ 12(b) contract; § 13(a) consent of the enrolling account holder / guardian for the honoree's sensitive attributes	With the event record, 5 years from event date (<i>counsel</i>)	Active (in <code>events.signature_details</code> ; no feature flag, no separate consent timestamp — documented as-is; see §11)	

5	Family graph — dependents & godparents. A dependent is a person, a pet, or anything the user cares for (dependent_kind). Only the person kind may carry name + birth date, sex, religion (+ guardian-consent timestamps) under the age fence; pet / other carry only a name + optional birthday — no sensitive data. Godparent: name, email (a third party), role, reminder preference	Account holder; their person-dependents (which may be a minor or an elder) ; godparents (third parties)	Optional milestone tracking (upcoming faith rites, godchild-birthday reminders)	§ 12(b) contract; § 13(a) guardian consent (timestamped) for a person-dependent's sensitive attributes; § 12(f) legitimate interest for godparent reminders	Life of account; deleted on withdrawal / account deletion. A person-child shared record is readable by a spouse account under a household model and retained after separation for continued co-parenting access (owner-defined)	Gated by NEXT_PUBLIC_DEPENDENT_P reported enabled in production (2026-07-13)
6	In-app messages — couple↔vendor chat	Couples, vendors	Enable coordination between parties	§ 12(b) contract	5 years from event date (<i>counsel</i>)	Active
7	Payment metadata — order amounts, reference codes, channel, payment-proof screenshots	Paying users	Process + reconcile in-app payments; issue Official Receipts	§ 12(c) legal obligation (NIRC / BIR)	10 years — legal floor (BIR RR 17-2013)	Active

8	E-gift receiving methods (Pabuya) — the couple's own GCash / Maya / bank / PayPal handle, account name, and uploaded receiving-QR image	Couples	Display the couple's own gift-receiving details to their guests. Setnayan never holds, routes, or records the movement of money — the schema stores no amount, ledger, or settlement state	§ 12(b) contract (couple's own display data)	With the event record; deletable by the couple anytime	Active (public guest route reported enabled in production 2026-07-13)
9	Contracts + e-signatures	Couples, vendors	Vendor engagement records	§ 12(c) legal obligation; Civil Code Art. 1144	10 years — legal floor	Active
10	Vendor-verification identity data — government ID, business permits / registrations, and (where applicable) liveness selfie and sanctions / PEP screening result (<i>sensitive PI</i> — see §5)	Vendors (business owners)	Verify vendor legitimacy before a profile is trusted; marketplace safety	§ 12(b) contract; § 12(c)/(f) (fraud + AMLA-adjacent diligence)	Verification documents 90 days hot → cold retention to the statutory floor (<i>counsel</i>)	Active (documents collected; automated verification via Persona is staged — see §7)
11	Biometric — facial-geometry vectors (<i>sensitive PI</i>)	Guests/users who opt in (adults 18+)	Optional automatic photo-matching within a single event	§ 13(a) explicit opt-in consent , timestamped at enrolment	Per-event only; revocable on request; purged with media (≤5y)	Built; vector storage Dormant (enrolment currently image-only until the matching model is activated) — see §5
12	Device identifier — one-way hashed, first-party per-browser id	Signed-in users	Fraud prevention — detect fake / duplicate / sock-puppet accounts	§ 12(f) legitimate interest (fraud prevention + protecting vendors)	Life of account; rolling-prune device rows unused > 24 months (<i>counsel</i>)	Dormant — flag NEXT_PUBLIC_DEVICE_FING OFF in production; collects nothing pending DPO activation (§4)

13	Guest RSVP details — name, contact, meal preference / dietary restrictions (<i>health-adjacent</i>), plus-one, photo/face-recognition preferences	Guests entered/invited by the couple	Deliver RSVP, seating, catering counts, and media-tagging preferences	§ 12(b) contract; § 13(a) consent for dietary/health-adjacent + face-recognition preferences	With the event record, ≤5 years (<i>counsel</i>)	Active
14	Automatic technical data — IP address (truncated to first 3 octets for QR-scan events), browser user-agent, timestamps	Site visitors	Security, abuse-prevention, service operation	§ 12(f) legitimate interest	Provider default / with related record	Active
15	Product analytics — page views, clicks, funnel events (PostHog; no personal identifiers; opt-in via cookie consent)	Site visitors	Product improvement	§ 12(a) consent (cookie-consent gated; opt-out in profile)	Provider default	Active
16	Error/diagnostic logs — stack traces (Sentry; no message bodies, payment details, or guest data)	N/A (no PII by design)	Bug diagnosis + reliability	§ 12(f) legitimate interest; data-minimization	≤ 90 days	Active
17	Marketing consent / communication preferences (+ <code>marketing_consent_at</code>)	Couples, vendors	Proof of consent; honor preferences	§ 12(a) consent	Life of account + audit tail	Active
18	Support tickets	Users who contact support	Handle support requests	§ 12(b)/(f)	2 years	Active

Right-to-erasure interaction: an account-deletion request deletes the subject's personal data **except** records under a legal-hold floor (rows 7 & 9 — payments and contracts), which are retained under the legal-obligation basis for the statutory period and then disposed of. This carve-out is disclosed in the privacy notice. (*Known remediation: account*

4. Privacy Impact Assessment — Device-Fingerprint Capture (fraud prevention)

A PIA of the **newest and most scrutiny-worthy** processing activity (ROPA row 12). Built into the platform but **switched OFF behind a feature flag**; it collects nothing until the DPO authorizes activation. (As of 2026-07-13 the flag `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` is confirmed OFF in production. A separate draft Anti-Fraud Policy amendment references this processing as active from 2026-07-07; that statement is ahead of the actual flag state and is being corrected — see §11.)

4.1 What is processed and why

To protect couples and vendors from coordinated fraud (a single bad actor — often a competing vendor — spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer an inquiry), Setnayan must recognize when several "different" accounts are in fact the **same device**. On a signed-in session, the browser generates a **random identifier** stored in local storage; it is transmitted to Setnayan's server and **one-way hashed (SHA-256 with a server-side salt)**. Only the hash is stored, against the account. Two accounts sharing a device produce the same hash, which lets the existing fraud-clustering logic **flag them for human review** — it never auto-bans anyone.

4.2 Necessity and proportionality

- **Necessary:** vendors are charged per inquiry; fake inquiries are a direct, quantifiable financial harm, and account-level signals alone cannot detect one actor behind many accounts.
- **Proportionate / least-intrusive:** the signal is a **random id**, deliberately **not** a behavioral or biometric fingerprint (no canvas/font/WebGL probing) and uses **no third-party tracking SDK**. It identifies a *browser*, not a person's activity, and is never used for advertising, personalization, or cross-site tracking.

4.3 Legal basis

Legitimate interest under § 12(f): preventing fraud and protecting the marketplace and its vendors. Balancing test — the intrusion is minimal (a fraud-only pseudonymous hash), the interest is substantial, and the practice is disclosed. The data is **not** sensitive personal information.

4.4 Risks and mitigations

Risk	Mitigation
Re-identification of an individual	Value is a one-way hash of a random id (raw value never stored); pseudonymous; no linkage to browsing behavior
Function creep (used beyond fraud)	Purpose limitation enforced in code + policy; used only for identity-cluster fraud review; never sold or shared
Over-collection	Signed-in accounts only ; one hash per (account, device) + a last-seen timestamp; no IP stored for this signal
Data-subject unawareness	Already disclosed in the public privacy notice (the "Device identifier (fraud prevention)" section), ahead of activation
Unlawful retention	Retention clock (life of account; rolling-prune > 24 months); included in data export; deleted on account deletion

Activation without oversight	Flag-gated OFF ; activation requires DPO sign-off; fully reversible from a single toggle
------------------------------	---

4.5 Residual assessment

With the above controls, residual privacy risk is **LOW**. The privacy-notice disclosure is already published; the remaining gate is the DPO's activation decision.

5. Sensitive Personal Information (RA 10173 § 13)

RA 10173 § 3(l) / § 13 treats as **sensitive** an individual's race/ethnic origin, marital status, age, religious/philosophical/political affiliations, health, education, genetic or sexual life, and government-issued identifiers, and gives biometric data special status. Setnayan processes the following sensitive categories, each on the noted basis:

Sensitive category	Where it appears	Basis	Safeguards
Religion / faith	Self-profile religion (ROPA 2); wedding ceremony rite and Islamic-rite fields (mahr, seating posture, wali/witness/imam roles) and Chinese/Tsinoy rite (ROPA 4); dependent's religion (ROPA 5)	§ 13(a) explicit consent (self / guardian), timestamped where captured at profile level	Optional; withdrawable; never sold or used for advertising; faith surfaced only to the couple's own event workspace
Marital / civil status	Self-profile civil_status (ROPA 2)	§ 13(a) explicit consent, timestamped	Optional, reference-only
Age / minors' data	A person -dependent's birth date — only kind=person, and only a child (<18) or elder (>50); pets/other excluded (ROPA 5); christening child birth date + gender ; birthday celebrant age (ROPA 4)	§ 13(a) guardian consent; § 12(b) contract	Minors' data arises only where the responsible adult enters a child — it is not the defining purpose of the dependents table; heightened-care handling
Health-adjacent	Guest dietary restrictions / meal preference (ROPA 13); gender-reveal expected due-date (ROPA 4)	§ 13(a) consent	Collected only where the event requires it; not used beyond the event
Gender / sex	Self-profile sex (ROPA 2); dependent / honoree sex (ROPA 4-5)	§ 13(a) consent, timestamped at profile level	Optional; reference-only

Biometric — facial geometry	Optional per-event photo-matching (ROPA 11)	§ 13(a) explicit opt-in consent, timestamped	Adults 18+; scoped to a single event, never reused across events ; consent withdrawal permanently deletes the vector + selfie; vector storage currently dormant (enrolment image-only until the model activates)
Government ID + sanctions/PEP screening	Vendor verification (ROPA 10)	§ 12(b)/(c)/(f)	Vendor business owners only; restricted-access; retained to the statutory floor then disposed

Users who provide none of the optional categories (religion, civil status, gender, biometric enrolment, dependents) supply no sensitive personal information beyond what a given event type strictly requires. The presence of these sensitive categories is a basis for **NPC registration** (§ 5 IRR registration triggers).

Note (2026-07-13): the public notice **already** carries an accurate opt-in **Biometric data (facial recognition)** section (explicit consent, adults 18+, per-event scope, withdrawal → permanent deletion) and a **Device identifier (fraud prevention)** section — the earlier "notice denies biometrics / omits the device identifier" concern came from a **stale local checkout**, not the deployed **origin/main**. Face-vector storage is currently **dormant** (enrolment image-only until the matching model activates), which the section's opt-in framing already accommodates.

6. Data Subject Rights (RA 10173 § 16)

Setnayan honors the rights to be **informed, access, object, rectify/correct, erase or block, data portability, and to lodge a complaint / claim damages**. Operationally:

- **Access + portability:** a self-service "download my data" export (iteration 0025) that includes the sensitive-personalization and family-graph fields.
- **Erasure/blocking:** soft-delete → hard-delete of account data, subject only to the legal-hold carve-out (§ 3). Withdrawing religion / civil status / gender / biometric / dependent consent deletes the corresponding data.
- **Objection/withdrawal:** analytics opt-out (cookie consent + profile toggle); face-recognition consent revocation (deletes the vector); marketing-preference controls.
- **Correction:** profile/settings self-edit.
- **Complaints:** routed to the DPO at dpo@setnayan.com; **15-business-day** response SLA; the data subject retains the right to complain to the NPC.

7. Subprocessors and Cross-Border Transfers (§ 21)

Setnayan uses the following subprocessors. Cross-border transfers rely on § 21 and each provider's adequacy/contractual commitments.

Subprocessor	Function	Location	Notes
--------------	----------	----------	-------

Supabase	Database + authentication	Singapore	Primary data store; RLS enforced
Vercel	Web application hosting	United States	
Cloudflare	CDN + R2 object storage (media)	APAC / PH-region buckets	
Resend	Transactional email	United States	
Sentry	Server-side error monitoring (stack traces only, no PII)	United States	
PostHog Cloud	Product analytics (cookie-consent opt-in; no personal identifiers)	United States	
Anthropic	AI features (deterministic-assist / optional AI)	United States	No training on user data
Persona	Vendor identity verification	United States	Automated verification staged ; vendor documents currently reviewed by the Setnayan admin team. No data flows to Persona until activation (disclosed before it begins)
Google LLC	Google Drive / YouTube (only when the user connects the optional integration)	United States	OAuth, opt-in; Google Limited Use commitment (no AI/ML training)

TikTok	Patiktok video publish (only when the user connects the optional integration)	United States / Singapore	OAuth, opt-in; scopes limited to profile + video upload/publish
Suno	AI music generation for Pakanta / rendered videos	United States	Owned-catalog generation; no personal data in prompts

Cross-border destinations disclosed: Singapore (Supabase), United States (Vercel, Cloudflare account plane, Resend, Sentry, PostHog, Anthropic, Persona, Google, Suno), United States/Singapore (TikTok). Media objects reside in Cloudflare's PH-region R2 buckets.

8. Organizational, Physical, and Technical Security Measures

- **Access control:** database Row-Level Security (RLS) on all tables (enabled at table creation); role-scoped access; two-admin approval gates for major administrative decisions.
- **Cryptographic controls:** passwords hashed; the device identifier is a **one-way salted hash** (raw value never stored); OAuth grants encrypted at rest; transport over TLS.
- **Data minimization:** analytics carry no personal identifiers; error logs exclude message bodies, payment details, and guest data; IP truncated to 3 octets for QR-scan events. *(Minimization item: some aggregate dashboard views load fuller records than they display — a tightening pass is tracked in §11.)*
- **Content safety:** an NSFW filter is on by default and cannot be disabled.
- **Confidentiality by design:** vendor identity masking (a vendor sees only the couple's event display name + date, never their email or personal name unless shared).
- **Residency:** database in Singapore; media in PH-region object-storage buckets.
- **Breach response:** the DPO coordinates assessment and any NPC + data-subject notification within the periods required by the NPC's breach rules.

8a. Retention governance

Retention is bounded on both ends: **RA 10173 storage-limitation** as the maximum, and **statutory floors** as the minimum for financial and contractual records (BIR RR 17-2013 = 10 years for payments/Official Receipts; Civil Code Art. 1144 for contracts). Per-class periods are maintained in the **Data Retention Schedule (2026-07-11)**; periods marked *(counsel)* await external ratification.

9. Compliance Statement

Setnayan processes personal data under RA 10173 on the bases recorded in § 3, with retention bounded on both ends (RA 10173 storage-limitation as the maximum; BIR/Civil Code statutory floors as the minimum for financial and contractual records). Data subject rights are implemented and honored; sensitive personal information (religion, civil

status, gender, minors' data, health-adjacent data, biometric, and vendor government-ID) is processed only on the bases in § 5; the fraud-prevention device identifier is minimized, pseudonymized, and DPO-gated (currently dormant). The DPO is the proprietor and is the point of contact for the NPC and for data subjects.

Prepared by (DPO): _____ (Indalecio S. Casasola II) — dpo@setnayan.com

Date: 2026-07-13

10. Appendix — companion documents

- `Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md` — the reconciliation that drove the v2.0 expansion.
- `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md` — DPO one-pager for the device-fingerprint processing.
- `Data_Retention_Schedule_2026-07-11.md` — full per-class retention schedule + [PENDING COUNSEL] items.
- `NPC_Compliance/` pack — the deeper filing set (Privacy Manual, full RoPA, DPO Designation + NPCRS data sheet, Breach Policy, DPIA register, Face-Vector DPIA, Anti-Fraud DPIA). This dossier is the executive summary over that pack; the two must be kept consistent.
- `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` — the binding public policy (to be reconciled per §11).
- Public privacy notice — setnayan.com/privacy.
- `[[dpo-designation-owner]]` — DPO designation record.

11. Open items before filing (owner / DPO / external counsel)

Blocking on external counsel (this dossier is not legal advice):

1. External counsel review of this dossier + the retention periods marked (*counsel*), with specific attention to the **§ 3(I) / minors' data** cluster (dependents, christening child data, godparent third-party notification) and the vendor **AMLC/PEP + government-ID** screening basis.
2. Confirmation of the **NPC registration threshold** applicable to the business.

Owner / DPO actions (documentation + product):

3. **Public privacy notice — DONE (app PR #3215, 2026-07-13):** added the **faith / family / honoree / e-gift** disclosures + Anthropic/Suno subprocessors; the opt-in **biometric** and **device-identifier** sections were already present. Remaining notice work is wording refinement by counsel, not a coverage gap.
4. **Reconcile the older corpus documents** to the values in §1: align iscasasolai@gmail.com → dpo@setnayan.com and the 7-business-day SLA → 15 in the binding Privacy & Security Policy; add the **10-year floor** and the **vendor-verification retention class** to that policy's §4 retention table; add **Persona, TikTok, Suno** to its §10 subprocessor table.
5. **Device-fingerprint status:** correct the draft Anti-Fraud Policy amendment's "active since 2026-07-07" language to match the confirmed **flag-OFF** state, and gate the notice disclosure to activation.
6. **Known product remediation** (tracked, not blocking this draft): account hard-delete does not yet purge chat-message PII (Retention Schedule §4); the `events.signature_details` honoree fields (christening child data, gender-reveal due-date) collect sensitive data without a per-field consent timestamp — **documented as-is per owner direction**, flagged here for a future consent-instrumentation pass; and the dashboard data-minimization tightening in §8.

Filing note. This is a complete, DPO-prepared submission draft: the ROPA, PIA, sensitive-PI declaration, subprocessor list, security measures, and data-subject-rights implementation are all present and reconciled to the

as-built platform as of 2026-07-13. It is **ready for external counsel review**, which — together with items 1-2 above — is the final gate before lodging with the NPC.